

SMRO-86187: Generic authentication API for Conversation Component

Author	@Rahul Jawale
Jira Ticket	SMRO-86187: Conversation Component on Record Page for Zoho CRM RELEASED TO US
Project(s)	https://git.txtbox.in:8080/smsmagicportal/smsmagicstories
Reviewers	@Pawan Arora
Remarks	

Document History

	Version No.	Release Date	Description	Prepared By	Reviewed By
1	1.0	7 Mar 2020	Initial Draft	@Yashpal Meena	@Sandip More
2					

CRM Authentication API — Technical Documentation

API Version: v2

Endpoint: `/api/v2/crm/authenticate`

Resource Class: `CRMAuthentication`

File Location: `engine/resources/authentication_v2/crm_auth.py`

Overview

The **CRM Authentication API** enables secure authentication across multiple CRM platforms. It returns **access tokens** and **refresh tokens** based on CRM type, and sets authentication cookies for session management.

It supports:

- **Zoho native accounts** (using `state` and `zuserId`)
- **Generic CRM integrations** (using `apiKey` , `userId` , `signature` , and `timestamp`)

Endpoint Details

Property	Description
URL	<code>/api/v2/crm/authenticate</code>
Method	<code>GET</code>
Authentication	API key, signature, or Zoho native tokens
Response Type	JSON
Sets Cookies	Yes
Redirect URL Support	Yes (passed via request parameter, added to response header)

Class Structure

```
1 class CRMAuthentication(Resource):
2     decorators = [handle_exceptions]
3
4     @use_kwargs(CRMAuthSchema())
5     def get(self, crm, state=None, userId=None, zuserId=None,
6         apiKey=None, signature=None, timestamp=None, type=None):
```

Schema Validation

The API validates input using `Marshmallow` schema.

Parameter	Required	Description
<code>crm</code>		CRM type identifier (e.g., <code>zoho</code> , <code>salesforce</code>)
<code>state</code>		Zoho-specific user state token

<code>userId</code>	—	User identifier
<code>zuserId</code>	—	Zoho user identifier
<code>apiKey</code>	—	API key for authentication
<code>signature</code>	—	Signature for verification
<code>timestamp</code>	—	Timestamp for signature validation
<code>type</code>	—	Authentication type (e.g., <code>native</code> , <code>generic</code>)

🔑 Authentication Flows

1 Zoho CRM Native Authentication

Condition: `crm = "zoho"` AND `type = "native"`

Required Parameters

- `zuserId`
- `state`

Process Flow

1. Validate parameters (`zuserId` , `state`)
2. Call internal CRM identity API (`_call_crm_identity_api`)
3. Receive and return access + refresh tokens
4. Set authentication cookies
5. Attach redirect URL to response header (if provided)

Internal API Call

Property	Value
URL	<code>{ZOH0_PORTAL_LOGIN_BASE_URL}/v1/zoho/identity</code>
Method	<code>POST</code>

Payload

```
{"userId": userId, "state": state}
```

2 Generic CRM Authentication

Condition: All non-Zoho or non-native flows

Required Parameters

- signature
- timestamp
- apiKey
- userId

Process Flow

1. Validate parameters
2. Generate expected signature using `fetch_signature()`
3. Verify provided signature
4. On success, generate OTP-based login response with tokens
5. Set cookies and attach redirect URL if present

Environment Variable

`ZOHO_PORTAL_LOGIN_BASE_URL` — defines CRM identity API base path.

Dependencies

- `requests` — Internal API communication
- `flask` — Response & cookie handling
- `marshmallow` — Request validation
- `webargs` — Parameter parsing

Response Handling

Success (200)

```
1 {  
2   "access_token": "jwt_access_token",  
3   "refresh_token": "jwt_refresh_token",  
4   "status": "success",  
5   "crm": "zoho"  
6 }  
7
```

❌ Common Error Responses

Error Type	HTTP Code	Example
Missing Zoho Params	401	<pre>{"error": "Missing required parameters: zuserId and state"}</pre>
Invalid Signature	401	<pre>{"error": "UNAUTHORIZED", "message": "Invalid signature"}</pre>
Generic Failure	500	<pre>{"error": "Authentication failed", "message": "Error details"}</pre>

🍪 Cookie Management

Cookie	Description	Attributes
mAgIC_pAnDa	Access Token	<pre>SameSite=None; HttpOnly; Secure; Path=/'</pre>
mAgIC_r_pAnDa	Refresh Token	<pre>SameSite=None; HttpOnly; Secure; Path=/'</pre>

Example

```
1 if access_token:
2     response.headers.add('Set-Cookie', f'mAgIC_pAnDa={access_token};
  SameSite=None; HttpOnly; Secure; Path=/'')
3 else:
4     response.headers.add('Set-Cookie', f'mAgIC_pAnDa=; SameSite=None;
  Secure; HttpOnly; Path=/'')
5
```

Security Features

Feature	Description
Signature Verification	Uses <code>fetch_signature()</code> to validate requests
Error Sanitization	Prevents sensitive info leakage
Cookie Security	Enforced <code>HttpOnly</code> , <code>Secure</code> , and <code>SameSite=None</code>
Centralized Error Handling	via <code>handle_exceptions</code> decorator

Logging & Monitoring

Log Levels

Level	Purpose
INFO	Successful authentication
WARNING	Missing/invalid parameters
ERROR	Authentication or API failure
DEBUG	Signature generation and token details

Sample Log Messages

- CRM authentication request - CRM: {crm}, State: {state}, UserId: {userId}
- Signature verification successful for CRM authentication
- Error in CRM authentication: {error_details}

Integration Points

Component	Description
-----------	-------------

CRM Identity API	Handles Zoho authentication
OTP Auth API	Generates OTP-based token responses
Utilities	<code>fetch_signature()</code> , <code>handle_exceptions()</code>

Usage Examples

Zoho Native Authentication

```
1 curl -X GET "https://your-domain.com/api/v2/crm/authenticate?  
2   crm=zoho&type=native&zuserId=zoho_user_123&state=state_token_456"
```

Generic CRM Authentication

```
1 curl -X GET "https://your-domain.com/api/v2/crm/authenticate?  
2   crm=salesforce&userId=user_123&apiKey=api_key_456&signature=generated_s  
   ignature&timestamp=1234567890"
```

Error Scenarios

Scenario	Description
Missing Zoho Params	<code>zuserId</code> or <code>state</code> missing
Missing Generic Params	Missing <code>apiKey</code> , <code>signature</code> , <code>timestamp</code> , or <code>userId</code>
Invalid Signature	Signature mismatch
API Call Failure	CRM identity API failure
Invalid CRM Type	Validation error in schema